

Mapeo normativo detallado de las preguntas de la encuesta

Nota: las referencias normativas son de alto nivel y deben adaptarse a la versión exacta de cada marco (ENS vigente, transposición nacional de NIS2, textos de DORA, etc.).

1. Convenciones

- **Codigo_Pregunta:** identificador único usado en la encuesta (por ejemplo, GOV-01).
- **Dominio:** grupo temático principal.
- **Marco_Normativo:** principal marco de referencia asociado.
- **Referencia_Alta_Nivel:** indicación del tipo de requisito o sección relevante (sin entrar en detalle de artículos concretos para mantener generalidad).
- **Tipo_Requisito:**
- **OBLIGATORIO:** suele implicar requerimiento legal/regulatorio para ciertos sectores/organizaciones.
- **RECOMENDADO:** buena práctica habitual en normas ISO u orientaciones supervisoras.

2. Tabla de mapeo

Codigo_Pregunta	Dominio	Tema resumido	Marco_Normativo principal	Referencia_Alta_Nivel	Tipo_Requisito
ORG-01	ORG	Tipo de organización	-	-	-
ORG-02	ORG	Tamaño de organización	-	-	-
ORG-03	ORG	Ámbito geográfico	-	-	-
ORG-04	ORG	Rol de la persona encuestada	-	-	-
ORG-05	ORG	Autopercepción de madurez	-	-	-
GOV-01	GOV	Estrategia de ciberseguridad /BCM	ENS, NIS2, ISO 27001	Gobierno y organización de la seguridad, estrategia nacional/orga nizativa	OBLIGATORIO / RECOMENDADO
GOV-02	GOV	Integración ciberseguridad –BCM	ENS, ISO 27001, ISO 22301	Enfoque integral de seguridad y continuidad	RECOMENDADO
GOV-03	GOV	Implicación de alta dirección	NIS2, DORA, ISO 27001	Responsabilidad de la dirección, supervisión y reporting	OBLIGATORIO / RECOMENDADO
GOV-04	GOV	Roles y responsabilidades formales	ENS, ISO 27001	Organización de la seguridad, funciones claras	OBLIGATORIO / RECOMENDADO
GOV-05	GOV	Coordinación entre áreas	ENS, ISO 27001, ISO 22301	Coordinación interna de seguridad y continuidad	RECOMENDADO
GOV-06	GOV	Presupuesto dedicado	NIS2, DORA	Recursos adecuados para gestión de riesgos TIC	OBLIGATORIO / RECOMENDADO

RISK-01	RISK	Marco de gestión de riesgos	ENS, NIS2, ISO 27005	Gestión de riesgos de seguridad de la información/TIC	OBLIGATORIO / RECOMENDADO
RISK-02	RISK	Frecuencia de análisis de riesgos	ENS, NIS2, ISO 27005	Revisión periódica de riesgos	OBLIGATORIO / RECOMENDADO
RISK-03	RISK	Alcance del análisis de riesgos	ENS, NIS2, ISO 27005	Cobertura de procesos, activos y servicios esenciales	OBLIGATORIO / RECOMENDADO
RISK-04	RISK	Criterios de priorización	ISO 27005, marcos de riesgo corporativo	Metodología de valoración y priorización	RECOMENDADO
RISK-05	RISK	Vinculación riesgos-BIA/B CM	ENS, ISO 22301	Integración de análisis de impacto y riesgo	RECOMENDADO
VULN-01	VULN	Inventario para gestión de vulnerabilidades	ENS, ISO 27001	Gestión de activos y configuración	OBLIGATORIO / RECOMENDADO
VULN-02	VULN	Proceso de escaneo y remediación	ENS, NIS2, ISO 27001	Gestión de vulnerabilidades y parches	OBLIGATORIO / RECOMENDADO
VULN-03	VULN	Integración vulnerabilidades-BCM	ENS, ISO 22301	Consideración de debilidades técnicas en continuidad	RECOMENDADO
VULN-04	VULN	Métricas de exposición a vulnerabilidades	NIS2, ISO 27001	Monitorización de seguridad	RECOMENDADO
PENT-01	PENT	Frecuencia de pentests	NIS2, DORA, ISO 27001	Pruebas de seguridad y evaluación continua	OBLIGATORIO / RECOMENDADO

PENT-02	PENT	Alcance de pentests	NIS2, DORA, ISO 27001	Cobertura de sistemas críticos en pruebas	RECOMENDADO
PENT-03	PENT	Uso de resultados de pentests	NIS2, DORA	Medidas de mitigación y mejora continua	OBLIGATORIO / RECOMENDADO
PENT-04	PENT	Coordinación pentests-BCM	ENS, ISO 22301	Integración de hallazgos técnicos en continuidad	RECOMENDADO
SIEM-01	SIEM	Implantación de SIEM/monitorización	ENS, NIS2, ISO 27001	Detección de incidentes, monitorización continua	OBLIGATORIO / RECOMENDADO
SIEM-02	SIEM	Cobertura de logs y eventos	ENS, ISO 27001	Registro de actividad y correlación	OBLIGATORIO / RECOMENDADO
SIEM-03	SIEM	Capacidad de detección temprana	NIS2	Detección y notificación rápida de incidentes	OBLIGATORIO / RECOMENDADO
SIEM-04	SIEM	Integración SIEM-IR-BCM	ENS, ISO 22301	Coordinación entre detección, respuesta y continuidad	RECOMENDADO
SIEM-05	SIEM	Uso de métricas de monitorización	NIS2, ISO 27001	Indicadores de rendimiento en seguridad	RECOMENDADO
BCM-01	BCM	Programa formal de BCM	ENS, ISO 22301, NIS2	Gestión de continuidad de negocio	OBLIGATORIO / RECOMENDADO
BCM-02	BCM	Análisis de impacto (BIA)	ENS, ISO 22301	Identificación de procesos críticos y impactos	OBLIGATORIO / RECOMENDADO
BCM-03	BCM	Definición de RTO/RPO	ENS, ISO 22301	Objetivos de tiempo y punto de recuperación	RECOMENDADO

BCM-04	BCM	Cobertura de BCP	ENS, ISO 22301	Planes de continuidad para procesos críticos	OBLIGATORIO / RECOMENDADO
BCM-05	BCM	Pruebas de continuidad	ENS, ISO 22301, NIS2	Ejercicios y tests periódicos de BCP	OBLIGATORIO / RECOMENDADO
BCM-06	BCM	Escenarios ciber en BCP	NIS2, ISO 22301	Consideración de ciberincidentes en continuidad	OBLIGATORIO / RECOMENDADO
BCM-07	BCM	Operación en modo degradado	ENS, ISO 22301	Procedimientos alternativos para servicios esenciales	RECOMENDADO
BCM-08	DRP	Planes de recuperación TIC (DRP)	ENS, ISO 22301, ISO 27001	Recuperación de infraestructuras y servicios críticos	OBLIGATORIO / RECOMENDADO
AWARE-01	AWARE	Programa de formación en ciberseguridad	ENS, NIS2, ISO 27001	Concienciación y formación de personal	OBLIGATORIO / RECOMENDADO
AWARE-02	AWARE	Formación en continuidad y crisis	ENS, ISO 22301	Capacitación en gestión de crisis y BCP	RECOMENDADO
AWARE-03	AWARE	Simulaciones (phishing, crisis)	NIS2, ISO 27001	Pruebas de concienciación y respuesta	RECOMENDADO
AWARE-04	AWARE	Implicación de dirección en concienciación	NIS2, ISO 27001	Liderazgo y cultura de seguridad	RECOMENDADO
AWARE-05	AWARE	Medición de eficacia de formación	ISO 27001	Evaluación de acciones de concienciación	RECOMENDADO
AWARE-06	AWARE	Cultura de reporte de incidentes	ENS, NIS2	Procedimientos de notificación y reporte interno	OBLIGATORIO / RECOMENDADO
MET-01	MET	Disponibilidad de métricas	ENS, NIS2, ISO 27001	Monitorización y mejora continua	RECOMENDADO

MET-02	MET	Frecuencia de reporte de métricas	NIS2, DORA	Reporting periódico a la dirección	RECOMENDA DO
MET-03	MET	Indicadores de resiliencia (RTO/RPO, MTTR)	ENS, ISO 22301	Medición de capacidad de recuperación	RECOMENDA DO
MET-04	MET	Indicadores adelantados (simulacros, exposición)	ENS, NIS2	Indicadores proactivos de riesgo y resiliencia	RECOMENDA DO
MET-05	MET	Vinculación de métricas con objetivos	ISO 27001, marcos de gestión	Gestión por objetivos de seguridad y continuidad	RECOMENDA DO
ROI-01	ROI	Evaluación económica de iniciativas	DORA (sector financiero), buenas prácticas	Evaluación de coste-benefici o de controles	RECOMENDA DO
ROI-02	ROI	Uso de escenarios de pérdida	NIS2, DORA, gestión de riesgos	Análisis de impacto de incidentes	RECOMENDA DO
ROI-03	ROI	Comunicación del valor de la resiliencia	NIS2, DORA	Información a la dirección y stakeholders	RECOMENDA DO
SUP-01	SUP	Gestión de riesgos de terceros	NIS2, DORA, ISO 27001, ISO 27036	Seguridad en la cadena de suministro TIC	OBLIGATORIO / RECOMENDA DO
SUP-02	SUP	Requisitos de continuidad en contratos	NIS2, DORA, ISO 22301	Cláusulas de BCP/DRP en contratos críticos	OBLIGATORIO / RECOMENDA DO
SUP-03	SUP	Participación de proveedores en ejercicios	NIS2, DORA, ISO 22301	Coordinación con terceros en pruebas	RECOMENDA DO
SUP-04	SUP	Visibilidad sobre cadena de suministro digital	NIS2, ISO 27036	Mapeo de dependencias y subproveedore s	RECOMENDA DO
ECO-01	ECO	Participación en iniciativas sectoriales/na cionales	Estrategias nacionales, GCI/NCSI	Colaboración y cooperación en ciberseguridad	RECOMENDA DO

ECO-02	ECO	Coordinación con autoridades y CERTs	NIS2, ENS	Notificación de incidentes y cooperación operativa	OBLIGATORIO / RECOMENDADO
ECO-03	ECO	Posición en el ecosistema de ciber-resiliencia	GCI/NCSI, buenas prácticas	Rol de la organización en el ecosistema	RECOMENDADO

3. Uso práctico del mapeo

Este mapeo permite:

- Identificar rápidamente qué respuestas bajas se corresponden con riesgos potenciales de incumplimiento (especialmente para ENS, NIS2 y DORA).
- Priorizar acciones que tengan un doble beneficio:
- Mejoran la madurez interna.
- Refuerzan el alineamiento con marcos normativos.
- Facilitar la conversación entre áreas técnicas, jurídicas y de cumplimiento, usando las preguntas de la encuesta como puente común.

Es recomendable mantener este archivo sincronizado con:

- Cambios en la encuesta (nuevas preguntas, reordenación, etc.).
- Actualizaciones normativas relevantes.